

CISSP Printable Practice Exam 22 - Domain 6 - Security Assessment and Testing

Practice Exam 03 - Domain 6

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-099)

Scenario: A consumer lending company wants to test its public application before launch. Management needs both an outsider's view of the attack surface and thorough coverage of authenticated functions that are available only to approved customers.

Which testing strategy BEST satisfies both objectives?

- A. Use only black-box testing because any tester knowledge would reduce realism.
- B. Use only white-box source review because external attack-surface testing adds no assurance.
- C. Combine an initial external black-box phase with an authorized gray-box phase using controlled customer access.
- D. Limit testing to a review of the application's security requirements.

Question 2 (CISSP3-100)

Scenario: A health benefits administrator plans to outsource a critical records-processing service. The proposed provider will permit questionnaires but does not agree to supply independent assurance reports or support customer audits after a material incident.

What should the security manager recommend BEFORE the agreement is signed?

- A. Define proportionate rights to obtain assurance evidence and conduct or commission audits under specified conditions.
- B. Accept the questionnaire because contractual audit provisions are unnecessary for outsourced services.
- C. Require unrestricted testing of every provider system at any time without coordination.
- D. Transfer responsibility for evaluating the provider entirely to the procurement department.

Question 3 (CISSP3-101)

Scenario: A telecommunications company is preparing for a regulatory security audit. A senior executive asks the audit liaison to provide assessors only with evidence that has already been screened to remove records showing control failures.

What is the BEST response by the audit liaison?

- A. Comply because executive management owns the audit relationship.
- B. Send all company records to the assessors without regard to scope or confidentiality.
- C. Cancel the audit until every control failure has been corrected.
- D. Provide complete evidence within the authorized scope and escalate the attempted restriction through established governance channels.

Question 4 (CISSP3-102)

Scenario: A municipal transit authority is planning an assessment of remote administrative access. The draft plan says only that the team will determine whether access is secure.

Which TWO additions would MOST improve the plan? Select 2 of the 5 options below.

- A. Identify the systems, interfaces, identities, and time period included in scope.
- B. Define evaluation criteria and the evidence required to determine whether controls

operate effectively.

- C. Permit assessors to change production controls whenever they find a weakness.
- D. Guarantee that the assessment will discover every possible vulnerability.
- E. Exclude exceptions from the report so the overall conclusion remains concise.

Question 5 (CISSP3-103)

Scenario: An audit found that database administrators shared a privileged account. Management reports that individual accounts have now been created and asks for immediate closure of the finding.

What should the audit team do NEXT?

- A. Close the finding based on management's statement of completion.
- B. Verify that individual accounts are used, shared access is disabled, and relevant activity is attributable before closure.
- C. Keep the finding open permanently because privileged-access findings cannot be remediated.
- D. Transfer ownership of the finding to the external auditor and stop internal follow-up.

Question 6 (CISSP3-104)

Scenario: A national charity rapidly deployed a donor platform after its previous service failed. Leadership needs prompt assurance before a major campaign, but several operational controls have not existed long enough to support testing across an extended period.

Which strategy is MOST appropriate?

- A. Delay all assessment work until a full year of evidence exists.
- B. Issue an unqualified conclusion about long-term effectiveness based on one day of observation.
- C. Assess design and current implementation now, then schedule follow-up testing of operating effectiveness after sufficient evidence accumulates.
- D. Review only the former service because it has a longer evidence history.

Question 7 (CISSP3-105)

Scenario: A vulnerability scanner flags an obsolete encryption protocol on dozens of servers. Administrators state that the protocol is disabled and suspect the scanner inferred support from service banners.

What should the assessment team do FIRST?

- A. Perform targeted validation using configuration evidence and controlled connection attempts on a representative sample.
- B. Report every result as confirmed because scanner output is authoritative.
- C. Delete every result because the administrators dispute it.
- D. Reclassify the finding as a policy issue without examining the servers.

Question 8 (CISSP3-106)

Scenario: During an authorized penetration test of a research network, a tester's activity causes an application cluster to become unstable. The rules of engagement identify service degradation as a mandatory stop condition.

What is the tester's BEST immediate action?

- A. Continue until the objective is achieved so the test remains realistic.
- B. Erase the test logs so the degradation is not mistaken for a security incident.
- C. Attempt an unapproved configuration change to restore stability before telling

anyone.

D. Stop the affected activity, preserve relevant evidence, and notify the designated contacts through the escalation process.

Question 9 (CISSP3-107)

Scenario: A smart-building gateway accepts messages from multiple sensor types. Testers need to identify crashes and unsafe error handling caused by unexpected message structures and boundary values.

Which technique BEST addresses this objective?

- A. Fuzz the interface with malformed, unexpected, and boundary-value inputs while monitoring behavior.
- B. Review employee completion records for secure coding training.
- C. Count the number of legitimate messages processed during normal operation.
- D. Inspect the physical labels attached to the gateway.

Question 10 (CISSP3-108)

Scenario: A ticketing application's automated test suite reports high overall statement coverage. The security reviewer discovers that exception handlers and the administrative authorization branch are never executed by the tests.

What is the MOST accurate conclusion?

- A. The high aggregate percentage proves security testing is complete.
- B. Statement coverage makes misuse-case testing unnecessary.
- C. Coverage is inadequate for the security objective because material branches and error paths remain untested.
- D. Only the total number of test cases matters when evaluating coverage.

Question 11 (CISSP3-109)

Scenario: A shipping portal calls a separate authorization service before releasing high-value orders. The assessment team is concerned that network timeouts could cause the portal to approve requests without a decision.

Which TWO tests are MOST relevant? Select 2 of the 5 options below.

- A. Simulate an authorization-service timeout and verify that the order is not released.
- B. Return an explicit authorization error and confirm that the portal denies the request and records the failure.
- C. Measure the portal's page font size during normal authorization.
- D. Increase the order value without disrupting the authorization dependency.
- E. Review only the authorization service's marketing description.

Question 12 (CISSP3-110)

Scenario: A wholesale distributor prohibits one user from both creating a supplier and approving payments to that supplier. A quarterly compliance check must determine whether the restriction is effective.

Which procedure provides the STRONGEST evidence?

- A. Review the written segregation-of-duties policy and stop if it is approved.
- B. Analyze current role combinations and execute controlled transactions to confirm prohibited actions are blocked.
- C. Ask department managers whether employees understand the restriction.
- D. Count the total number of suppliers added during the quarter.

Question 13 (CISSP3-111)

Scenario: A software company reports that nearly all critical vulnerabilities were remediated on time. The metric excludes vulnerabilities that remain open because only closed items are included in its denominator.

What is the PRIMARY reporting problem?

- A. The metric uses a percentage instead of a raw count.
- B. The metric must be accurate because all closed items have completion dates.
- C. Critical vulnerabilities should never be included in a performance indicator.
- D. The population definition creates selection bias and overstates remediation performance.

Question 14 (CISSP3-112)

Scenario: An assessment tool assigns the same high technical severity to a weakness on an isolated test server and to the same weakness on an internet-facing system that supports customer payments.

How should the assessor prioritize the findings?

- A. Use the tool severity unchanged because organizational context would make results less objective.
- B. Lower both findings because automated tools sometimes produce false positives.
- C. Evaluate exposure, business impact, exploitability, and compensating controls before assigning remediation priority.
- D. Prioritize the isolated server first because test systems are easier to remediate.

Question 15 (CISSP3-113)

Scenario: A manufacturing group is supporting an external audit involving several business units. Evidence requests are arriving through email, and different teams have begun sending overlapping files directly to individual auditors.

What should the audit coordinator implement FIRST?

- A. A centralized request register with owners, due dates, scope review, submission status, and approved evidence locations.
- B. A rule allowing any employee to send any potentially relevant record immediately.
- C. A requirement that the external auditors locate all evidence without organizational assistance.
- D. A shared public folder containing every security document held by the company.

Question 16 (CISSP3-114)

Scenario: A university states that department heads recertify application access every six months. The assessor must determine whether the process covers the complete user population and results in removal of access that is no longer justified.

Which TWO evidence sets would be MOST useful? Select 2 of the 5 options below.

- A. A reconciliation of the reviewed population to authoritative account and personnel records.
- B. Records showing that rejected access was removed within the required period.
- C. A screenshot of the application's sign-in page.
- D. The number of pages in the access-control procedure.
- E. A list of future features planned for the application.

Question 17 (CISSP3-115)

Scenario: A legacy finance application cannot enforce the required password length. Management deploys additional access restrictions and enhanced review of authentication records, then claims that the original finding has been fully remediated.

How should the assessor report the result?

- A. Close the finding as direct remediation because additional controls exist.
- B. Certify that the application meets the password requirement without further analysis.
- C. Ignore the compensating controls because only the original control can reduce risk.
- D. Evaluate the compensating controls, document that the original deficiency remains, and report the resulting residual risk.

Question 18 (CISSP3-116)

Scenario: A retail chain corrected a recurring failure in security exception approvals by redesigning the workflow. One compliant approval was demonstrated immediately after deployment, and management requests closure of the long-standing finding.

What is the BEST follow-up approach?

- A. Close the finding because one successful transaction proves sustained effectiveness.
- B. Wait for an appropriate operating period, then test a risk-based sample to determine whether the redesigned workflow works consistently.
- C. Reopen every prior audit finding regardless of its relationship to the workflow.
- D. Assess only whether users prefer the new interface.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-099) - Correct: C

A phased approach preserves an outsider's perspective first and then adds controlled knowledge and credentials to examine authenticated functions more deeply. Black-box testing alone may miss restricted paths, source review does not reproduce the exposed attack surface, and requirements review cannot demonstrate operating behavior.

Question 2 (CISSP3-100) - Correct: A

The contract should preserve practical, proportionate access to assurance evidence, including conditions for additional review when risk changes or incidents occur. A questionnaire alone may be insufficient, unrestricted testing creates operational and legal concerns, and security assurance cannot be delegated solely to procurement.

Question 3 (CISSP3-101) - Correct: D

Audit evidence must be complete and responsive to the authorized scope; intentionally suppressing adverse records undermines the engagement. Escalation preserves governance and transparency. Cancellation is not the liaison's unilateral remedy, while indiscriminate disclosure would violate scope and confidentiality controls.

Question 4 (CISSP3-102) - Correct: A, B

A defensible assessment needs explicit boundaries and predefined criteria tied to sufficient evidence. Assessors should not alter production controls without authorization, complete vulnerability discovery cannot be guaranteed, and material exceptions must inform the conclusion rather than be omitted.

Question 5 (CISSP3-103) - Correct: B

Closure should follow validation that the corrective action is implemented and achieves the intended control outcome. Creating accounts alone does not prove shared access ended or accountability works. Permanent findings are inappropriate after effective remediation, and internal follow-up responsibility is not removed by possible external review.

Question 6 (CISSP3-104) - Correct: C

Layered assurance addresses immediate design and implementation risk without overstating what limited history can prove, then tests sustained operation when enough evidence exists. Waiting leaves current risk unassessed, a one-day review cannot support a long-term conclusion, and the retired service is not the relevant target.

Question 7 (CISSP3-105) - Correct: A

Targeted verification determines whether the flagged condition is actually present and helps establish the extent of any confirmed weakness. Scanner results and administrator statements are both inputs, not conclusive evidence. Automatic acceptance, deletion, or reclassification would bypass necessary validation.

Question 8 (CISSP3-106) - Correct: D

A defined stop condition requires the tester to halt the harmful activity and use the agreed escalation path while preserving evidence. Continuing violates authorization, unapproved remediation may worsen impact, and deleting logs damages accountability and analysis.

Question 9 (CISSP3-107) - Correct: A

Fuzz testing exercises an interface with unexpected or malformed input to expose crashes, validation failures, and unsafe error handling. Training records, normal transaction counts, and physical labels may support other reviews but do not test input robustness directly.

Question 10 (CISSP3-108) - Correct: C

Aggregate statement coverage can conceal gaps in security-critical branches and error paths. Coverage must be interpreted against risk and intended behaviors, not treated as a universal completeness measure. Misuse cases and the substance of tests remain important regardless of test count.

Question 11 (CISSP3-109) - Correct: A, B

Timeout and explicit-error tests directly verify that the consuming portal fails securely and records the control failure when its dependency cannot provide a valid authorization decision. Presentation characteristics, normal requests, and descriptive material do not test the suspected fail-open condition.

Question 12 (CISSP3-110) - Correct: B

Role analysis identifies conflicting assignments, while controlled transactions test whether the application actually enforces the restriction. Policy and interviews show intent or awareness, and supplier counts do not demonstrate segregation-of-duties effectiveness.

Question 13 (CISSP3-111) - Correct: D

Excluding still-open items removes the cases most likely to show missed deadlines, producing a biased denominator and an overstated result. Percentages can be useful when populations are defined correctly, and the presence of dates on closed records does not establish completeness.

Question 14 (CISSP3-112) - Correct: C

Technical severity is an input to risk, not a complete business priority. Exposure, impact, exploitability, and effective compensating controls can produce different priorities for the same weakness. Automatic acceptance, reduction, or ease-based ordering would not reflect organizational risk.

Question 15 (CISSP3-113) - Correct: A

A controlled request register reduces duplication, assigns accountability, tracks completeness, and helps ensure evidence is reviewed and delivered within scope. Uncoordinated or public disclosure creates confidentiality and version risks, while refusing reasonable facilitation impedes the audit.

Question 16 (CISSP3-114) - Correct: A, B

Population reconciliation shows whether all relevant accounts reached the review, and removal records demonstrate that review decisions produced timely control action. A sign-in page, procedure length, and future feature list do not establish recertification completeness or effectiveness.

Question 17 (CISSP3-115) - Correct: D

Compensating controls may reduce risk but do not change the fact that the original requirement is unmet. The assessor should test those controls and communicate residual risk accurately. Treating them as direct remediation, ignoring their effect, or certifying unsupported compliance would misstate the evidence.

Question 18 (CISSP3-116) - Correct: B

A single demonstration supports implementation but not sustained operating effectiveness. Follow-up should allow enough operation to generate representative evidence and then test a risk-based sample. Unrelated findings and user preference do not answer whether the corrective control works consistently.

